

Web Application Communication Fundamentals

To identify anomalies in a SOC environment, an analyst must first understand the underlying technology. Web applications primarily communicate using the **Hyper-Text Transfer Protocol (HTTP)**.

1. Protocol Overview

- **OSI Layer:** HTTP operates at **Layer 7 (Application Layer)**.
 - **Dependencies:** It relies on lower-layer protocols: **Ethernet (Layer 2)**, **IP (Layer 3)**, **TCP (Layer 4)**, and **SSL/TLS (Layer 6)** for encryption.
 - **Communication Model:** A request-response cycle between a **Client** (e.g., Browser) and a **Server**.
-

2. HTTP Requests (The Client's "Ask")

An HTTP request is used to retrieve resources (HTML, video, JSON). It must follow a standard format to be understood by the server.

Structure:

1. **Request Line:** Contains the Method (GET, POST, etc.) and the Resource Path (/).
2. **Request Headers:** Metadata processed by the server.
3. **Message Body:** Data sent to the server (primarily used in POST methods).

Key Headers for Security Analysis:

- **Host:** Identifies the specific domain requested (essential for servers hosting multiple sites).
 - **Cookie:** Stores session information to keep users logged in.
 - **User-Agent:** Contains browser and OS information. *SOC Tip: Automated scanners often have unique User-Agents.*
 - **Accept-Language:** Tells the server the client's preferred language.
 - **Connection:** `close` ends the TCP connection after the response; `keep-alive` maintains it.
-

3. HTTP Responses (The Server's "Answer")

After processing the request (checking databases or logic), the server sends a response back to the client.

Structure:

- 1. **Status Line:** Contains the HTTP version and the **Status Code**.
- 2. **Response Headers:** Metadata about the server and the data being sent.
- 3. **Response Body:** The actual requested resource (e.g., HTML code, image data).

HTTP Status Code Summary:

Range	Category	Description
100-199	Informational	Request received, continuing process.
200-299	Success	The action was successfully received and accepted (e.g., 200 OK).
300-399	Redirection	Further action needs to be taken to complete the request.
400-499	Client Error	The request contains bad syntax or cannot be fulfilled (e.g., 404 Not Found).
500-599	Server Error	The server failed to fulfill a valid request (e.g., 500 Internal Error).

Common Response Headers:

- **Server:** Discloses the web server software and version (e.g., Apache/2.4.41).
- **Content-Type:** Defines the type of data (e.g., `text/html` , `application/json`).
- **Content-Length:** The size of the data in the Response Body.
- **Last-Modified:** Used for caching; shows when the resource was last updated.

SOC Analyst Application

Understanding this structure allows you to:

- 1. **Detect Scanners:** Spot unusual `User-Agent` strings or high volumes of `404` errors.
- 2. **Verify Attacks:** A `200 OK` on a suspicious URL (like a `.php` shell) confirms a successful exploit.
- 3. **Identify Exfiltration:** Large `Content-Length` values in outbound responses may indicate data theft.

